

Drilldown

Analyst: Benjamin Liu

Date: 6/3/2026

Executive Summary

On August 10, 2016, Threat hunting team discovered suspicious connection to EC2 instances which is out of normal business pattern. The attacker first gained unauthorized access to the Joomla administration panel via brute-force credential attacks originating from 23.22.63.114. In Joomla/administrator/ path, subsequent investigation revealed two malicious payloads uploaded to the web server with a HTTP POST quest from the attacker, including a trojan software which is used to hide malicious behaviors, such as loader and backdoor, and a php file to build webshell. Web server we1149srv is the only infected machine. There is no further evidence to prove that exfiltration and lateral movement happened. Mapping to MitreAttack the attack chain involves C2, credential access, stealth, execution. Immediate remediation actions include isolating the affected host, blocking attacker IP addresses at the firewall, removing malicious payloads, and resetting Joomla administrator credentials. Short- and long-term controls are detailed in the Remediation section.

Senario

Your organization doesn't use Amazon Web Services, so when a Threat Hunter starts seeing connections to multiple EC2 instances, it's time to start hunting to understand what happened, so the information can be passed to the incident response team, and indicators can be gather for intelligence sharing.

Timeline

TIME	TYPE	IOCs	OPERATOR
------	------	------	----------

08-10-2016@15:52:45	Virus detected; upload file	virus="W32/Swrort.Cltr" ; dtype="Virus" ; ref="http[:]//www[.]fortinet[.]com/ve?vn=W32%2FSwrort.C%21tr"; virusid=1706341 ; filename 3791.exe;	Alarm from: fortigate_utm
08-10-2016@21:45:21~ 21:46:51.394	Brute force	username=admin&0960d493674eb04861bd64da9b662118=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=arthur; (100+) Http-method: POST	Attacker SrcIP: 23[.]22[.]63[.]114
08-10-2016@21:50:31	upload file	URI: "/joomla/administrator/index.php?option=com_installer&view=install " HTTP method: POST filename: agent.php	Attacker src_ip : 40[.]80[.]148[.]42:49474
08-10-2016@21:50:31~ 22:21:34	HTTP GET request	refer : "http[:]//www[.]google[.]ml/url?sa=t&rct=j&q=39.18&source=web&cd=077&ved=4VPTJIOHX&url=39&ei=315GkrmqofZQiDalczaDE0&usg=zg0vLgdcefYdxMSA41QI4HLcZiS9M5VWav" ; (100+) request :GET /joomla/agent.php HTTP/1.1;	Attacker src_ip : 40[.]80[.]148[.]42

08-10-2016@21:52: 47	upload files	reference: "http[:]//imreallynotbatman[.]com/joomla/administrator/index[.]php?option=com_extplorer&tmpl=component; part_filename":["3791.exe","agent.php"]; Http method: POST dstip:192[.]168[.]250[.]70	Attacker SrcIP:40[.]80[.]148[.]42
08-10-2016@21:55: 22~ 22:21:34	HTTP Get request	refer: "http[:]//www[.]google[.]ge/url?sa=t&rct=j&source=web&cd=999&ved=422S6hzhfP&ei=es4FIEBQgF69AxYiTkOxs6&usg=f95vb7hQYhuEt0MHm69toQuv45ifXrle1K " (194+) request :GET /joomla/agent.php HTTP/1.1	Attacker SrcIP: 23[.]22[.]63[.]114
08-10-2016@21:56: 18~ 22:08:13	Execution	cmd.exe /c "3791.exe 2>&1	NT AUTHORITY\IUSR

IOCs

- Virus="W32/Swrort.C!tr" ; dtype="Virus" ;

ref="http[:]//www[.]fortinet[.]com/ve?vn=W32%2FSwrort.C%21tr"; virusid=1706341

;
- C:\inetpub\wwwroot\joomla\3791.exe on host we1149srv

- Forge reference:

`http[:]//www[.]google[.]ge/url?sa=t&rct=j&source=web&cd=999&ved=422S6hzhfP
&ei=es4FIEBQgF69AxYiTkOxs6&usg=f95vb7hQYhuEt0MHm69toQuv45ifXrle1K [`

Forged domain of Google, and attached random arguments to disguise as normal user traffic to avoid IDS/WAF filter.]

- 3791.exe was executed by account "NT AUTHORITY\IUSR" with commandline
"cmd.exe /c "3791.exe 2>&1"
- Intranet IP address of the victim server is 192[.]168[.]250[.]70, Extranet IP address of the victim server is 71[.]39[.]18[.]126
- Attacker's ip address:
 - 40[.]80[.]148[.]42
 - 23[.]22[.]63[.]114, associated with AWS service hostname :
ec2-23-22-63-114.compute-1.amazonaws.com
- Initial access url : /joomla/administrator/index.php
- UserAgent used by attacker to upload malicious files: Mozilla/5.0 (Windows NT 6.1; WOW64; Trident/7.0; rv:11.0) like Gecko
- Hash of 3791.exe:
EC78C938D8453739CA2A370B9C275971EC46CAF6E479DE2B2D04E97CC47FA45D
- " GET /joomla/agent.php" requested from both 23[.]22[.]63[.]114 and
40[.]80[.]148[.]42

- Victim web Server
 - Private IP: 192[.]168[.]250[.]70
 - Public IP : 71[.]39[.]18[.]126
 - Hostname : we1149srv.waynecorpinc.local
 - Host website domain: imreallynotbatman.com

Remediation Suggestions

- For immediate action:
 - Taking the Site offline and setting white-list for access..
 - Limiting the connection from IP address 40[.]80[.]148[.]42 and 23[.]22[.]63[.]114 at firewall and web proxy.
 - Force logout of all accounts and reset administrator and database credentials at the control panel of Joomla.
 - Removing the malicious executable 3791.exe and agent.php from C:\inetpub\wwwroot\joomla\ on host we1149srv.
- For short-term plan:
 - Limit access to the Joomla administration panel to only internal networks.
 - Perform vulnerability scans; Patch the vulnerabilities of Joomla ; Upgrade the Joomla software and related plugins.
 - Create a complete forensic image of the we1149srv server.

- For Long-term plan:
 - Configuring Suricata to against the malicious HTTP request from AWS
 - building unauthorized cloud service usage monitoring baseline
 - scheduling periodic web penetration test on the web sever

MITRE ATTACK Mapping

Technique ID	Note	IOCs
T1105	Ingress tool transfer	"http[:]//imreallynotbatman[.]com/joomla/administrator/index[.]php?option=com_extplorer&tmpl=component;part_filename":["3791.exe","agent.php"];
T1110	Brute Force	username=admin&0960d493674eb04861bd64da9b662118=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=arthur; (100+) Http-method: POST
T1036	Masquerading	http[:]//www[.]google[.]ml/url?sa=t&rct=j&q=39.18&source=web&cd=077&ved=4VPTJlOHX&url=39&ei=315GkrmqofZQidalczaDE0&usg=zg0vLgdcefYdxMSA41Ql4HLcZiS9M5VWav
T1059.003	command and scripting interpreter:windows command line	cmd.exe /c "3791.exe 2>&1
T1078	Valid Accounts	

T1071	Application Layer protocol	Attacker sent Post request to agent.php and run cmd commandline
-------	----------------------------	---

Investigation Screenshot

- **Amazon EC2** (Elastic Compute Cloud) is a core AWS service that lets you rent virtual computers (instances) to run applications in the cloud.
- **Domain of AWS** : amazonaws.com
- **Subdomain of EC2**: compute.amazonaws.com

Question 1) WayneCorpInc doesn't use Amazon Web Service for cloud hosting, so when a threat hunting discovered outbound connections to EC2 instances they immediately began to drilldown into this activity so they can provide as much context for the Incident Response Team as possible. Using Sysmon logs, how many destination hostnames are found? (Format: # Destination EC2s) (3 points)

3

Correct! ✓


```

a dvc_nt_host 100+
# event_id 100+
# EventCode 1
a EventData_Xml 100+
# EventID 1
# EventRecordID 100+
a eventtype 2
a Guild 1
# Id 100+
a Image 5
a index 1
a Initiated 2
a Keywords 1
# Level 1
# linecount 2
a Name 1
# Opcode 1
a ProcessGuid 7
# ProcessId 7
a ProcessId 4

```

Image

5 Values, 100% of events

Selected

Reports

Top values Top values by time Rare values

Events with this field

Values	Count	%
System	1,430	87.195%
C:\Windows\System32\svchost.exe	203	12.378%
C:\Program Files (x86)\PHP\v5.5\php-cgi.exe	3	0.183%
C:\Windows\System32\dns.exe	3	0.183%
C:\inetpub\wwwroot\joomla\3791.exe	1	0.061%

From the field image, I find a suspicious executable named 3791.exe.

65

Community Score

65/71 security vendors flagged this file as malicious

ec78c938d8453739ca3a370b9c275971ec46caf6473dc2b2d04e97cc41fa45d

ab.exe

Size: 72.07 KB

Last Analysis Date: 2 months ago

peexe checks-user-input idle detect-debug-environment overlay

DETECTION DETAILS RELATIONS BEHAVIOR COMMUNITY 244

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Code insights

This binary is a trojanized version of the ApacheBench (ab.exe) utility. While it contains legitimate strings and metadata related to Apache performance testing (e.g., 'Requests per second', 'Zeus Technology Ltd'), the underlying code structure reveals malicious obfuscation and payload delivery mechanisms. The entry point (.start at 0x40a0c4) consists of a sequence of BCD instructions (AAA, DAA, AAS, DAS) which are almost exclusively used in manual assembly obfuscation or shellcode. Decompile of sub_40abf0 and sub_40acd7 shows manual decryption loops using XOR (0x0e) and obfuscated calls to LoadLibraryA. These techniques are used to hide malicious behavior, such as a loader or backdoor, within a legitimate-looking benchmarking tool.

Popular threat label: trojan.sworrt/rozena

Threat categories: trojan

Family labels: sworrt rozena cryptz

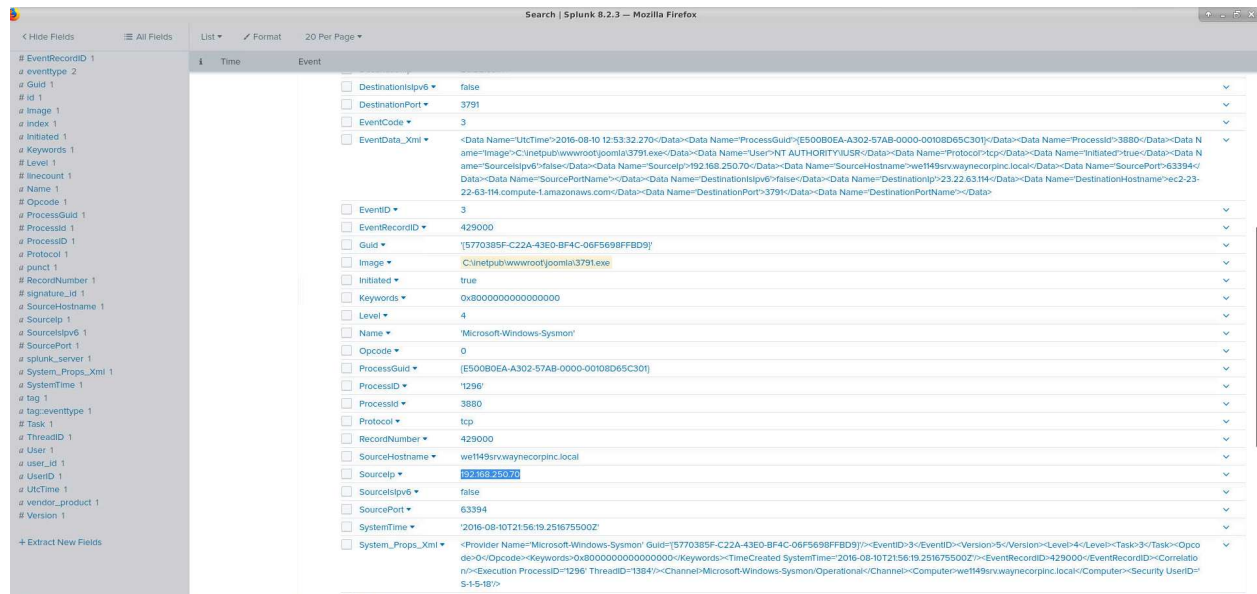
Security vendors' analysis

Acronis (Static ML)	Suspicious	AhnLab-V3	Trojan.Win32.Shell.R1283
Alibaba	Trojan-Win32/CobaltStrike.5c89	AllCloud	Backdoor:Win/meterpreter.A
Antiy-AVL	Trojan.Win32.Rozena	Arcabit	Trojan.CryptZ.Marte.1.Gen
Arctic Wolf	Unsafe	Avast	Win32-SwPatch (Wrm)
AVG	Win32-SwPatch (Wrm)	Avira (no cloud)	TR/Patched.Gen2

Question 4) What is the hostname and internal IP address of the system that initiated this connection? (Format: Hostname, X.X.X.X) (3 points)

we1149srv.waynecorpinc.local, 192.168.250.

Correct! ✓



Clicking the 3791.exe in the field image, I got more details about the executable.

Question 5) What time was this connection event? Use TimeCreated SystemTime (Format: YYYY-MM-DDTHH:MM:SS) (3 points)

2016-08-10 21:56:19

Correct! ✓

Question 6) What is the destination hostname and IP address of the AWS EC2 instance? (Format: Hostname, X.X.X.X) (3 points)

ec2-23-22-63-114.compute-1.amazonaws.com

Correct! ✓

The screenshot shows the Sysmon event viewer interface. The search bar contains the query: `* "amazonaws.com" source="WinEventLog:Microsoft-Windows-Sysmon/Operational" Image="C:\\inetpub\\wwwroot\\joomla\\3791.exe"`. The event list shows a single event at 8/10/16 9:56:19.000 PM. The event details pane shows the following information:

- Event ID:** 1
- Time:** 8/10/16 9:56:19.000 PM
- Source:** WinEventLog:Microsoft-Windows-Sysmon/Operational
- Source type:** xmlwineventlog
- Channel:** Microsoft-Windows-Sysmon/Operational
- Computer:** we149srv.waynecorpinc.local
- DestinationHost:** ec2-23-22-63-114.compute-1.amazonaws.com
- DestinationIP:** 23.22.63.114
- DestinationIPV6:** false
- DestinationPort:** 3791
- EventCode:** 3
- EventData_Xml:**

```
<Data Name="UtcTime">2016-08-10 12:53:32.370</Data><Data Name="ProcessGuid">{E500B0EA-A302-57AB-0000-0010B065C301}</Data><Data Name="ProcessId">3880</Data><Data Name="Image">C:\\inetpub\\wwwroot\\joomla\\3791.exe</Data><Data Name="User">NT AUTHORITY\\USER</Data><Data Name="Protocol">tcp</Data><Data Name="Initiated">true</Data><Data Name="SourceIP">false</Data><Data Name="SourcePort">192.168.258.78</Data><Data Name="SourceHost">we149srv.waynecorpinc.local</Data><Data Name="DestinationIP">false</Data><Data Name="DestinationIPV6">false</Data><Data Name="DestinationPort">23.22.63.114</Data><Data Name="DestinationHost">ec2-23-22-63-114.compute-1.amazonaws.com</Data><Data Name="DestinationPortName">3791</Data></EventData></Event>
```

Time of the connection built by 3791.exe at 21:56:19.

Question 7) Utilize Sysmon logs to find the SHA256 hash of the executable making this connection. What is the hash value? (Format: SHA256 Hash) (5 points)

EC78C938D8453739CA2A370B9C275971EC

Correct! ✓

The screenshot shows the Sysmon event viewer interface. The search bar contains the query: `* source="WinEventLog:Microsoft-Windows-Sysmon/Operational" Image="C:\\inetpub\\wwwroot\\joomla\\3791.exe" EventID=1`. The event list shows a single event at 8/10/16 9:56:18.000 PM. The event details pane shows the following information:

- Event ID:** 1
- Time:** 8/10/16 9:56:18.000 PM
- Source:** WinEventLog:Microsoft-Windows-Sysmon/Operational
- Source type:** xmlwineventlog
- Channel:** Microsoft-Windows-Sysmon/Operational
- Computer:** we149srv.waynecorpinc.local
- DestinationHost:** ec2-23-22-63-114.compute-1.amazonaws.com
- DestinationIP:** 23.22.63.114
- DestinationIPV6:** false
- DestinationPort:** 3791
- EventCode:** 3
- EventData_Xml:**

```
<Data Name="UtcTime">2016-08-10 12:53:32.370</Data><Data Name="ProcessGuid">{E500B0EA-A302-57AB-0000-0010B065C301}</Data><Data Name="ProcessId">3880</Data><Data Name="Image">C:\\inetpub\\wwwroot\\joomla\\3791.exe</Data><Data Name="User">NT AUTHORITY\\USER</Data><Data Name="Protocol">tcp</Data><Data Name="Initiated">true</Data><Data Name="SourceIP">false</Data><Data Name="SourcePort">192.168.258.78</Data><Data Name="SourceHost">we149srv.waynecorpinc.local</Data><Data Name="DestinationIP">false</Data><Data Name="DestinationIPV6">false</Data><Data Name="DestinationPort">23.22.63.114</Data><Data Name="DestinationHost">ec2-23-22-63-114.compute-1.amazonaws.com</Data><Data Name="DestinationPortName">3791</Data></EventData></Event>
```

I searched for the eventID=1 and the 3791.exe. Then I got one item which includes the sha256 hash of 3791.exe.

Question 8) Search this hash online to find more about its reputation. On the Behaviour tab look at the results for Microsoft Sysinternals. What two IPv4 addresses are listed, that begin with 23.216.? (Format: X.X.X.X, X.X.X.X) (3 points)

23.216.147.64, 23.216.147.76

Correct! ✓

65/71 security vendors flagged this file as malicious

ec78c938d8453739ca2a37069c275971ec46cafe479dc2b2d04e97cc47fa5d

ab.exe

Size: 72.07 KB | Last Analysis Date: 2 months ago

peexe checks-user-input idle detect-debug-environment overlay

DETECTION DETAILS RELATIONS BEHAVIOR COMMUNITY (24)

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

☐ Display grouped sandbox reports

Sandbox	Verdict	Analysis Date	Analysis Time	Analysis Size	Analysis Type	Analysis Status	Analysis Details
CAPA	Malicious	1 month ago	1 min	1 MB	1 MB	1 MB	1 MB
CAPE Sandbox	Malicious	1 month ago	1 min	1 MB	1 MB	1 MB	1 MB
DAS-Security Orcas	Malicious	1 month ago	1 min	1 MB	1 MB	1 MB	1 MB
Microsoft Sysinternals	Malicious	1 month ago	1 min	1 MB	1 MB	1 MB	1 MB
Tencent HAO	Malicious	1 month ago	1 min	1 MB	1 MB	1 MB	1 MB
VirusTotal CuckooFork	Malicious	1 month ago	1 min	1 MB	1 MB	1 MB	1 MB
VirusTotal Jijubox	Malicious	1 month ago	1 min	1 MB	1 MB	1 MB	1 MB
Zenbox	Malicious	1 month ago	1 min	1 MB	1 MB	1 MB	1 MB

Search sha256 of the malicious at Virustotal.

```
UDP a83f:8110:30a3:38a3:40a3:48a3:50a3:58a3:53
TCP 23.216.147.76:443
TCP 104.86.182.43:443
TCP 20.99.132.105:443
UDP a83f:8110:0:0:2000:0:0:0:53
UDP a83f:8110:0:0:2800:0:0:0:53
TCP 13.107.39.203:80
UDP a83f:8110:2800:1800:4000:1800:1800:100:53
TCP 20.62.24.77:443
TCP 23.216.147.64:443
UDP a83f:8110:6f6f:6b75:7046:756e:6374:696f:53
```

I get many IP address from the Behaviour column. Then, I used ctrl+f to find 23.216 at the page.

There are 3 IP address marked. Two of them are very similar with with other.

Question 9) Using these two gathered IPs, check to see if there is any activity from them in Splunk, which there might not be! What is the number of events per IP where the address is mentioned ANYWHERE in a log? (Format: IP1EventCount, IP2EventCount) (3 points)

0, 0

Correct! ✓

splunk>enterprise Apps

Search Analytics Datasets Reports Alerts Dashboards

New Search

1 * "23.216.147"

✓ 0 events (before 5/29/26 1:42:52.000 AM) No Event Sampling

Events (0) Patterns Statistics Visualization

No results found.

There is no item about ip address "23.216.147". So, i just search the

Question 10) At what time was this file uploaded to the web server? (Use 'timestamp' value) (Format: YYYY-MM-DDTHH:MM:SS) (4 points)

2016-08-10T21:52:47

Correct! ✓

1 * "3791.exe"
2 | sort -_time

✓ 76 events (before 5/29/26 2:29:01.000 AM) No Event Sampling

Events (76) Patterns Statistics Visualization

Format Timeline Zoom Out Zoom to Selection Disabled 1 minute per column

List Format 20 Per Page

Hide Fields All Fields

	Time	Event
>	8/10/16 9:52:45.000 PM	Aug 10 15:52:45 192.168.250.1: data=2016-08-10 time=15:52:45 devname=gotham-fortigate devid=FGT604614044725 logid=0211008193 type=route subtype=virus eventtype=infected level=notice vdr=root msg=File is infected. action=monitored service=HTTP sessionid=923537 srcip=40.80.148.42 dstip=192.168.250.78 srcport=49490 dtpport=80 dstintf=internal3 policyid=26 proto=6 direction=outgoing filename=3791.exe quarskip=No-skip virus=W32/Swroot.Clttr dtype=Virus ref=http://www.fortinet.com/ve?vm=W32/Swroot.Clttr virusid=1706341 url=http://imreallynotbatman.com/joomla/administrator/index.php profile=Honeypot -Access user="" agent=Mozilla/5.0 analyticscksum=ec78c938d845735ca2a370b99c275971ec48caf6479d62b204e97cc47fa45d analyticssubmit=false csrcore=50 crlevel=critical host=192.168.250.1 source=udp/514 sourcetype=fortigate_utm
>	8/10/16 9:52:47.035 PM	({"endtime":"2016-08-10T21:52:47.035552Z","timestamp":"2016-08-10T21:52:45.437445Z","accept":{"text/html,application/xhtml+xml,*/*","accept_language":"en-US","ack_packets_in":1,"ack_packets_out":55,"bytes_in":77896,"bytes_out":77648,"bytes_out":248,"c_ip":"40.80.148.42","cached":0,"capture_hostname":"demo-01","client_rtt":0,"client_rtt_packets":0,"client_rtt_sum":0,"connection_type":"Keep-Alive","content_disposition":{"form-data; name='userfile(0)'; filename='3791.exe'","form-data; name='userfile(1)'; filename='agent.php'","form-data; name='userfile(2)'; filename='\\'","form-data; name='userfile(3)'; filename='\\'","form-data; name='userfile(4)'; filename='\\'","form-data; name='userfile(5)'; filename='\\'","form-data; name='userfile(6)'; filename='\\'","form-data; name='userfile(7)'; filename='\\'","form-data; name='userfile(8)'; filename='\\'","form-data; name='userfile(9)'; filename='\\'","form-data; name='userfile(10)'; filename='\\'","form-data; name='userfile(11)'; filename='\\'","form-data; name='userfile(12)'; filename='\\'","form-data; name='userfile(13)'; filename='\\'","form-data; name='userfile(14)'; filename='\\'","form-data; name='userfile(15)'; filename='\\'","form-data; name='userfile(16)'; filename='\\'","form-data; name='userfile(17)'; filename='\\'","form-data; name='userfile(18)'; filename='\\'","form-data; name='userfile(19)'; filename='\\'","form-data; name='userfile(20)'; filename='\\'","form-data; name='userfile(21)'; filename='\\'","form-data; name='userfile(22)'; filename='\\'","form-data; name='userfile(23)'; filename='\\'","form-data; name='userfile(24)'; filename='\\'","form-data; name='userfile(25)'; filename='\\'","form-data; name='userfile(26)'; filename='\\'","form-data; name='userfile(27)'; filename='\\'","form-data; name='userfile(28)'; filename='\\'","form-data; name='userfile(29)'; filename='\\'","form-data; name='userfile(30)'; filename='\\'","form-data; name='userfile(31)'; filename='\\'","form-data; name='userfile(32)'; filename='\\'","form-data; name='userfile(33)'; filename='\\'","form-data; name='userfile(34)'; filename='\\'","form-data; name='userfile(35)'; filename='\\'","form-data; name='userfile(36)'; filename='\\'","form-data; name='userfile(37)'; filename='\\'","form-data; name='userfile(38)'; filename='\\'","form-data; name='userfile(39)'; filename='\\'","form-data; name='userfile(40)'; filename='\\'","form-data; name='userfile(41)'; filename='\\'","form-data; name='userfile(42)'; filename='\\'","form-data; name='userfile(43)'; filename='\\'","form-data; name='userfile(44)'; filename='\\'","form-data; name='userfile(45)'; filename='\\'","form-data; name='userfile(46)'; filename='\\'","form-data; name='userfile(47)'; filename='\\'","form-data; name='userfile(48)'; filename='\\'","form-data; name='userfile(49)'; filename='\\'","form-data; name='userfile(50)'; filename='\\'","form-data; name='userfile(51)'; filename='\\'","form-data; name='userfile(52)'; filename='\\'","form-data; name='userfile(53)'; filename='\\'","form-data; name='userfile(54)'; filename='\\'","form-data; name='userfile(55)'; filename='\\'","form-data; name='userfile(56)'; filename='\\'","form-data; name='userfile(57)'; filename='\\'","form-data; name='userfile(58)'; filename='\\'","form-data; name='userfile(59)'; filename='\\'","form-data; name='userfile(60)'; filename='\\'","form-data; name='userfile(61)'; filename='\\'","form-data; name='userfile(62)'; filename='\\'","form-data; name='userfile(63)'; filename='\\'","form-data; name='userfile(64)'; filename='\\'","form-data; name='userfile(65)'; filename='\\'","form-data; name='userfile(66)'; filename='\\'","form-data; name='userfile(67)'; filename='\\'","form-data; name='userfile(68)'; filename='\\'","form-data; name='userfile(69)'; filename='\\'","form-data; name='userfile(70)'; filename='\\'","form-data; name='userfile(71)'; filename='\\'","form-data; name='userfile(72)'; filename='\\'","form-data; name='userfile(73)'; filename='\\'","form-data; name='userfile(74)'; filename='\\'","form-data; name='userfile(75)'; filename='\\'","form-data; name='userfile(76)'; filename='\\'","form-data; name='userfile(77)'; filename='\\'","form-data; name='userfile(78)'; filename='\\'","form-data; name='userfile(79)'; filename='\\'","form-data; name='userfile(80)'; filename='\\'","form-data; name='userfile(81)'; filename='\\'","form-data; name='userfile(82)'; filename='\\'","form-data; name='userfile(83)'; filename='\\'","form-data; name='userfile(84)'; filename='\\'","form-data; name='userfile(85)'; filename='\\'","form-data; name='userfile(86)'; filename='\\'","form-data; name='userfile(87)'; filename='\\'","form-data; name='userfile(88)'; filename='\\'","form-data; name='userfile(89)'; filename='\\'","form-data; name='userfile(90)'; filename='\\'","form-data; name='userfile(91)'; filename='\\'","form-data; name='userfile(92)'; filename='\\'","form-data; name='userfile(93)'; filename='\\'","form-data; name='userfile(94)'; filename='\\'","form-data; name='userfile(95)'; filename='\\'","form-data; name='userfile(96)'; filename='\\'","form-data; name='userfile(97)'; filename='\\'","form-data; name='userfile(98)'; filename='\\'","form-data; name='userfile(99)'; filename='\\'","form-data; name='userfile(100)'; filename='\\'","form-data; name='userfile(101)'; filename='\\'","form-data; name='userfile(102)'; filename='\\'","form-data; name='userfile(103)'; filename='\\'","form-data; name='userfile(104)'; filename='\\'","form-data; name='userfile(105)'; filename='\\'","form-data; name='userfile(106)'; filename='\\'","form-data; name='userfile(107)'; filename='\\'","form-data; name='userfile(108)'; filename='\\'","form-data; name='userfile(109)'; filename='\\'","form-data; name='userfile(110)'; filename='\\'","form-data; name='userfile(111)'; filename='\\'","form-data; name='userfile(112)'; filename='\\'","form-data; name='userfile(113)'; filename='\\'","form-data; name='userfile(114)'; filename='\\'","form-data; name='userfile(115)'; filename='\\'","form-data; name='userfile(116)'; filename='\\'","form-data; name='userfile(117)'; filename='\\'","form-data; name='userfile(118)'; filename='\\'","form-data; name='userfile(119)'; filename='\\'","form-data; name='userfile(120)'; filename='\\'","form-data; name='userfile(121)'; filename='\\'","form-data; name='userfile(122)'; filename='\\'","form-data; name='userfile(123)'; filename='\\'","form-data; name='userfile(124)'; filename='\\'","form-data; name='userfile(125)'; filename='\\'","form-data; name='userfile(126)'; filename='\\'","form-data; name='userfile(127)'; filename='\\'","form-data; name='userfile(128)'; filename='\\'","form-data; name='userfile(129)'; filename='\\'","form-data; name='userfile(130)'; filename='\\'","form-data; name='userfile(131)'; filename='\\'","form-data; name='userfile(132)'; filename='\\'","form-data; name='userfile(133)'; filename='\\'","form-data; name='userfile(134)'; filename='\\'","form-data; name='userfile(135)'; filename='\\'","form-data; name='userfile(136)'; filename='\\'","form-data; name='userfile(137)'; filename='\\'","form-data; name='userfile(138)'; filename='\\'","form-data; name='userfile(139)'; filename='\\'","form-data; name='userfile(140)'; filename='\\'","form-data; name='userfile(141)'; filename='\\'","form-data; name='userfile(142)'; filename='\\'","form-data; name='userfile(143)'; filename='\\'","form-data; name='userfile(144)'; filename='\\'","form-data; name='userfile(145)'; filename='\\'","form-data; name='userfile(146)'; filename='\\'","form-data; name='userfile(147)'; filename='\\'","form-data; name='userfile(148)'; filename='\\'","form-data; name='userfile(149)'; filename='\\'","form-data; name='userfile(150)'; filename='\\'","form-data; name='userfile(151)'; filename='\\'","form-data; name='userfile(152)'; filename='\\'","form-data; name='userfile(153)'; filename='\\'","form-data; name='userfile(154)'; filename='\\'","form-data; name='userfile(155)'; filename='\\'","form-data; name='userfile(156)'; filename='\\'","form-data; name='userfile(157)'; filename='\\'","form-data; name='userfile(158)'; filename='\\'","form-data; name='userfile(159)'; filename='\\'","form-data; name='userfile(160)'; filename='\\'","form-data; name='userfile(161)'; filename='\\'","form-data; name='userfile(162)'; filename='\\'","form-data; name='userfile(163)'; filename='\\'","form-data; name='userfile(164)'; filename='\\'","form-data; name='userfile(165)'; filename='\\'","form-data; name='userfile(166)'; filename='\\'","form-data; name='userfile(167)'; filename='\\'","form-data; name='userfile(168)'; filename='\\'","form-data; name='userfile(169)'; filename='\\'","form-data; name='userfile(170)'; filename='\\'","form-data; name='userfile(171)'; filename='\\'","form-data; name='userfile(172)'; filename='\\'","form-data; name='userfile(173)'; filename='\\'","form-data; name='userfile(174)'; filename='\\'","form-data; name='userfile(175)'; filename='\\'","form-data; name='userfile(176)'; filename='\\'","form-data; name='userfile(177)'; filename='\\'","form-data; name='userfile(178)'; filename='\\'","form-data; name='userfile(179)'; filename='\\'","form-data; name='userfile(180)'; filename='\\'","form-data; name='userfile(181)'; filename='\\'","form-data; name='userfile(182)'; filename='\\'","form-data; name='userfile(183)'; filename='\\'","form-data; name='userfile(184)'; filename='\\'","form-data; name='userfile(185)'; filename='\\'","form-data; name='userfile(186)'; filename='\\'","form-data; name='userfile(187)'; filename='\\'","form-data; name='userfile(188)'; filename='\\'","form-data; name='userfile(189)'; filename='\\'","form-data; name='userfile(190)'; filename='\\'","form-data; name='userfile(191)'; filename='\\'","form-data; name='userfile(192)'; filename='\\'","form-data; name='userfile(193)'; filename='\\'","form-data; name='userfile(194)'; filename='\\'","form-data; name='userfile(195)'; filename='\\'","form-data; name='userfile(196)'; filename='\\'","form-data; name='userfile(197)'; filename='\\'","form-data; name='userfile(198)'; filename='\\'","form-data; name='userfile(199)'; filename='\\'","form-data; name='userfile(200)'; filename='\\'","form-data; name='userfile(201)'; filename='\\'","form-data; name='userfile(202)'; filename='\\'","form-data; name='userfile(203)'; filename='\\'","form-data; name='userfile(204)'; filename='\\'","form-data; name='userfile(205)'; filename='\\'","form-data; name='userfile(206)'; filename='\\'","form-data; name='userfile(207)'; filename='\\'","form-data; name='userfile(208)'; filename='\\'","form-data; name='userfile(209)'; filename='\\'","form-data; name='userfile(210)'; filename='\\'","form-data; name='userfile(211)'; filename='\\'","form-data; name='userfile(212)'; filename='\\'","form-data; name='userfile(213)'; filename='\\'","form-data; name='userfile(214)'; filename='\\'","form-data; name='userfile(215)'; filename='\\'","form-data; name='userfile(216)'; filename='\\'","form-data; name='userfile(217)'; filename='\\'","form-data; name='userfile(218)'; filename='\\'","form-data; name='userfile(219)'; filename='\\'","form-data; name='userfile(220)'; filename='\\'","form-data; name='userfile(221)'; filename='\\'","form-data; name='userfile(222)'; filename='\\'","form-data; name='userfile(223)'; filename='\\'","form-data; name='userfile(224)'; filename='\\'","form-data; name='userfile(225)'; filename='\\'","form-data; name='userfile(226)'; filename='\\'","form-data; name='userfile(227)'; filename='\\'","form-data; name='userfile(228)'; filename='\\'","form-data; name='userfile(229)'; filename='\\'","form-data; name='userfile(230)'; filename='\\'","form-data; name='userfile(231)'; filename='\\'","form-data; name='userfile(232)'; filename='\\'","form-data; name='userfile(233)'; filename='\\'","form-data; name='userfile(234)'; filename='\\'","form-data; name='userfile(235)'; filename='\\'","form-data; name='userfile(236)'; filename='\\'","form-data; name='userfile(237)'; filename='\\'","form-data; name='userfile(238)'; filename='\\'","form-data; name='userfile(239)'; filename='\\'","form-data; name='userfile(240)'; filename='\\'","form-data; name='userfile(241)'; filename='\\'","form-data; name='userfile(242)'; filename='\\'","form-data; name='userfile(243)'; filename='\\'","form-data; name='userfile(244)'; filename='\\'","form-data; name='userfile(245)'; filename='\\'","form-data; name='userfile(246)'; filename='\\'","form-data; name='userfile(247)'; filename='\\'","form-data; name='userfile(248)'; filename='\\'","form-data; name='userfile(249)'; filename='\\'","form-data; name='userfile(250)'; filename='\\'","form-data; name='userfile(251)'; filename='\\'","form-data; name='userfile(252)'; filename='\\'","form-data; name='userfile(253)'; filename='\\'","form-data; name='userfile(254)'; filename='\\'","form-data; name='userfile(255)'; filename='\\'","form-data; name='userfile(256)'; filename='\\'","form-data; name='userfile(257)'; filename='\\'","form-data; name='userfile(258)'; filename='\\'","form-data; name='userfile(259)'; filename='\\'","form-data; name='userfile(260)'; filename='\\'","form-data; name='userfile(261)'; filename='\\'","form-data; name='userfile(262)'; filename='\\'","form-data; name='userfile(263)'; filename='\\'","form-data; name='userfile(264)'; filename='\\'","form-data; name='userfile(265)";

27.0.0.1:8000/en-US/app/search/search?earl..._ratio=1&workload_pool=&sid=1780021741.55#

search the malicious executable 3791.exe with chronological order. i get the item logged upload successfully for 3791.exe.

Mozilla/5.0 (Windows NT 6.1; WOW64; Tride

Correct! ✓

From the result of 3791.exe, I get the log of the uploaded malicious executable. Http_user_agent tag shows Mozilla which is the answer.

</joomla/administrator/index.php>

Correct! ✓

[illegible]

```
host = splunk-02    source = stream:http    sourcetype = stream:http
```

Correct! ✓

From the tag `c_ip`, I got the source ip of the initial access activity.

Question 14) We need to understand if any of our network defenses have detected this activity, or if we're completely blind. Use one of the retrieved indicators to search the logs to see if anything has flagged this file as being malicious. Provide any timestamp retrieved from a relevant log to show evidence of some kind of alert or notification (Format: YYYY-MM-DD HH:MM:SS) (5 points)

2016-08-10 15:52:45

Correct! ✓

The screenshot shows a security log viewer interface. At the top, a search bar contains the query "3791.exe" and the results are sorted by "_time". Below the search bar, a timeline visualization shows a single event. The event details are displayed in a table below the timeline.

Time	Event
Aug 10 15:52:45 192.168.250.1	date=2016-08-10 time=15:52:45 devname=gothan-fortigate devid=FGT6004614844725 logid=90211008193 type=utm subtype=virus eventtype=infected level=notice vid="root" msg="File is infected." action=monitored service=HTTP sessionid=923537 srcip=40.80.148.42 dstip=192.168.250.78 srcport=49490 dstport=80 dstintf="internal3" policyid=26 proto=6 direction=outgoing filename="3791.exe" quarant="skip" skip_virus="332/Swroot.Clt" dtype="Virus" ref="http://www.fortinet.com/ve/vn-w3252f/Swroot.C321tr" virusid=1706341 url="http://jreallnotbatman.com/joomla/administrator/index.php" profile="HoneyPot" --Access" user="" agent="Mozilla/5.0" analyticscksum="ec78c33d8453739ca2a378b9c275971ec46cafee479de2b2d04e97cc47fa45d" analyticssubmit=false crscore=50 crlevel=critical host=192.168.250.1 source=udp:514 sourcetype=fortigate_utm

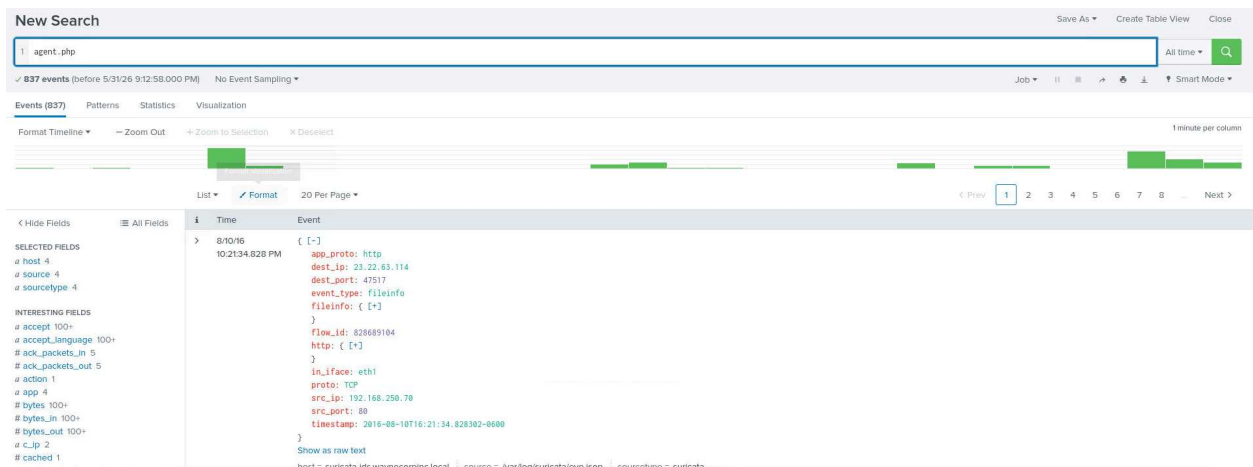
I notice that a log is associated with virus detected, so I read more detail about this item.

The screenshot shows a log entry with two fields: "date" and "time". The "date" field is set to "2016-08-10" and the "time" field is set to "15:52:45".

So I put the date and time together as an answer to the question.

Investigate the whole attack chain

- Then, I am going to investigate the other uploaded file, agent.php from the attacker. I search agent.php, and get 837 items. it



The earliest item shown attacker used POST request to the victim machine from srcip 40.80.148.42.

The http reference is

“http://vimreallynotbatman.com/vjoomlaVadministratorVindex.php?option=com_installer”. The file uploaded was agent.php.



I have noticed that attacker used many different agents to visit the victim machine.

< Hide Fields

≡ All Fields

a event_type 2

a eventtype 5

a expires 1

a file_name 1

a file_path 1

flow_id 100+

a ftnt_action 2

a hostname 1

a http.hostname 2

a http.http_content_type 1

a http.http_method 2

a http.http_refer 100+

a http.http_user_agent 100+

http.length 14

a http.protocol 1

http.status 2

a http.url 3

a http_comment 2

http_content_length 15

a http_content_type 2

a http_method 2

a http_protocol 1

a http_referrer 100+

a http_user_agent 100+

a ids_type 1

a in_iface 1

a index 1

a level 2

linecount 1

logid 2

a method 1

missing_packets_in 1

missing_packets_out 1

a msg 3

a network_interface 1

packets_in 5

http_user_agent

>100 Values, 53.046% of events

Selected

Yes

No

Reports

Top values

Top values by time

Rare values

Events with this field

Top 10 Values

Count

%

Mozilla/5.0 (Windows; U; Windows NT 5.1; en-US; rv:1.9.1.16) Gecko/20101130 Firefox/3.5.16 GTB7.1 6 1.351%

Mozilla/5.0 (Windows; U; Windows NT 5.1; en-US) AppleWebKit/528.8 (KHTML, like Gecko) Chrome/2.0.156.0 Version/3.2.1 Safari/528.8 5 1.126%

Mozilla/5.0 (Windows; U; Windows NT 6.0; de; rv:1.9.0.13) Gecko/2009073022 Firefox/3.0.13 (.NET CLR 4.0.20506) 5 1.126%

Mozilla/5.0 (Windows; U; Windows NT 6.0; en-US) AppleWebKit/530.19.2 (KHTML, like Gecko) Version/4.0.2 Safari/530.19.1 5 1.126%

Mozilla/5.0 (Windows NT 6.1; rv:2.0b6pre) Gecko/20100903 Firefox/4.0b6pre Firefox/4.0b6pre 5 1.126%

Mozilla/5.0 (Windows; U; Windows NT 6.1; tr; rv:1.9.1.9) Gecko/20100315 Firefox/3.5.9 GTB7.1 5 1.126%

Mozilla/5.0 (Macintosh; U; Intel Mac OS X 10_6_0; en-US) AppleWebKit/532.0 (KHTML, like Gecko) Chrome/4.0.203.4 Safari/532.0 4 0.901%

Mozilla/5.0 (Windows; U; Windows NT 6.1; en-US; rv:1.9.1) Gecko/20090624 Firefox/3.1b3;MEGAUPLOAD 1.0 (.NET CLR 3.5.30729) 4 0.901%

Mozilla/5.0 (X11; U; Linux i686; hu-HU; rv:1.9.0.7) Gecko/2009030422 Ubuntu/8.10 (intrepid) Firefox/3.0.7 FirePHP/0.2.4 4 0.901%

Opera/9.62 (Windows NT 6.1; U; de) Presto/2.1.1 4 0.901%

The attacker used 100+ different user agents to sent GET requests for testing the availability of the

< Hide Fields

≡ All Fields

a devid 1

a devname 1

a direction 1

a dstintf 1

a dstip 1

dstport 1

duplicate_packets_in 3

duplicate_packets_out 2

a dvc 2

a endtime 100+

a event_type 2

a eventtype 5

a expires 1

a file_name 1

a file_path 1

flow_id 100+

a fnt_action 2

a hostname 1

a http.hostname 2

a http.http_content_type 1

a http.http_method 2

a http.http_refer 100+

a http.http_user_agent 100+

http.length 14

a http.protocol 1

http.status 2

a http.uri 3

a http_comment 2

http_content_length 15

a http_content_type 2

a http_method 2

a http_protocol 1

a http_referrer 100+

a http_user_agent 100+

a ids_type 1

a in_iface 1

http_referrer

>100 Values, 53.046% of events

Selected

Yes

No

Reports

Top values

Top values by time

Rare values

Events with this field

Top 10 Values

	Count	%
http://71.39.18.126/?wNO=-YHXoVu_ZEYvNqELHNxhP692w17zRf	4	0.901%
http://71.39.18.126/?xC=G85xbe3I-XS8_Q-8jDyz0qaqIr-YHX&Pp=0Vu_ZEYvNqELHNxhP692w17zRfE2xD	4	0.901%
http://71.39.18.126/joomla/agent.php?wVz=27KDP5Qiyg9WM0nnye_5SLS_LevPhp	4	0.901%
http://translate.googleusercontent.com/translate_c?depth=1&rurl=translate.google.com&sl=auto&tl=en&u=39&usg=1hd3pZQh_gYvorKjPLcunmC0DIeiUFebJE	4	0.901%
http://www.google.com.mx/url?sa=t&rct=j&q=39&source=web&cd=210&ved=Cf-p6io6t&url=39.18&ei=e_AiFuHyDELMznspXkb0sx&usg=PEos6pgPv-Ka6fZNcFhVK0C_pf00lG9-Lv&sig2=oauZ0FzhEmW3vUtw0UiWVR	4	0.901%
http://www.google.com.mx/url?sa=t&rct=j&q=39&source=web&cd=210&ved=f-p6io6te&url=39.18&ei=_AiFuHyDELMznspXkb0sxP&usg=Eos6pgPv-Ka6fZNcFhVK0C_pf00lG9-Lvo&sig2=auZ0FzhEmW3vUtw0UiWVRX	4	0.901%
http://www.google.ge/url?sa=t&rct=j&source=web&cd=999&ved=G85xbe3I-&ei=XS8_Q-8jDyz0qaqIr-YHXo&usg=Vu_ZEYvNqELHNxhP692w17zRfE2xDCf-p6	4	0.901%
http://71.39.18.126/?BVw=4c4094q3Qx7NjAFxeaak	3	0.676%
http://71.39.18.126/?wNO=F9rGRZA084mydcVAa4cX	3	0.676%

a http.http_content_type 1
a http.http_method 2
a http.http_refer 100+
a http.http_user_agent 100+
http.length 14
a http.protocol 1
http.status 2
a http.uri 3
a http_comment 2
http_content_length 15
a http_content_type 2
a http_method 2
a http_protocol 1
a http_referrer 100+
a http_user_agent 100+
a ids_type 1

http.uri

3 Values, 29.63% of events

Selected

Yes

No

Reports

Top values

Top values by time

Rare values

Events with this field

Values

	Count	%
/joomla/agent.php	246	99.194%
/joomla/administrator/index.php	1	0.403%
/joomla/administrator/index.php?option=com_installer&view=install	1	0.403%

I do some research about Joomla. It is the second most popular **self-hosted Content Management System (CMS)** in the world. So, I got to know the attacker have visited the Joomla for connecting with Website backend system.

>	8/10/16 9:55:36.000 PM	Aug 10 15:55:36 192.168.250.1 date=2016-08-10 time=15:55:36 devname=gotham-fortigate devid=FGT6004614044725 logid=8317013312 type=utm subtype=webfilter eventtype=ftgd_allow level=notice vd=root policyid=26 sessionid=925003 user="" srcip=23.22.63.114 srcport=47367 dstip=192.168.250.70 dstport=80 dstintf=internal3 proto=6 service=HTTP hostname=71.39.18.126 profile=flow-monitor-all action=passthrough reqtype=direct url=/joomla/agent.php sentbyte=517 rcvbyte=0 direction=N/A msg="URL belongs to an allowed category in policy" method=domain cat=0 catdesc=Unrated host = 192.168.250.1 source = udp:514 sourcetype = fortigate_utm
>	8/10/16 9:55:36.000 PM	Aug 10 15:55:36 192.168.250.1 date=2016-08-10 time=15:55:36 devname=gotham-fortigate devid=FGT6004614044725 logid=8317013312 type=utm subtype=webfilter eventtype=ftgd_allow level=notice vd=root policyid=26 sessionid=925002 user="" srcip=23.22.63.114 srcport=47366 dstip=192.168.250.70 dstport=80 dstintf=internal3 proto=6 service=HTTP hostname=71.39.18.126 profile=flow-monitor-all action=passthrough reqtype=direct url=/joomla/agent.php sentbyte=431 rcvbyte=0 direction=N/A msg="URL belongs to an allowed category in policy" method=domain cat=0 catdesc=Unrated host = 192.168.250.1 source = udp:514 sourcetype = fortigate_utm
>	8/10/16 9:55:36.000 PM	Aug 10 15:55:36 192.168.250.1 date=2016-08-10 time=15:55:36 devname=gotham-fortigate devid=FGT6004614044725 logid=8317013312 type=utm subtype=webfilter eventtype=ftgd_allow level=notice vd=root policyid=26 sessionid=925001 user="" srcip=23.22.63.114 srcport=47365 dstip=192.168.250.70 dstport=80 dstintf=internal3 proto=6 service=HTTP hostname=71.39.18.126 profile=flow-monitor-all action=passthrough reqtype=direct url=/joomla/agent.php sentbyte=482 rcvbyte=0 direction=N/A msg="URL belongs to an allowed category in policy" method=domain cat=0 catdesc=Unrated host = 192.168.250.1 source = udp:514 sourcetype = fortigate_utm

- From this result about Agent.php, I learned that the public IP address of the website run by the victim server is 71.39.18.126 and internal ip address is 192.168.250.70.
- About The virus detected at 08-10-2016@15:52:45, I got a result on Google, which explains where 3791.exe came from.

"W32/Swrort.C!tr" (detected as [Trojan:Win32/Swrort](#) by Microsoft and [Trojan.Swrort](#) by Malwarebytes) is a severe Trojan and backdoor that allows unauthorized hackers to access your PC, steal data, and download additional malicious files.  Malwarebytes +1

What This Trojan Does

- **Backdoor Access:** Opens your system to remote attackers, allowing them to take control or infiltrate your network.
- **Malware Dropper:** Downloads and installs secondary malware (such as ransomware or spyware) silently.
- **System Disruption:** Often hides in system files, creating sluggish performance, random crashes, and blocking Task Manager or antivirus updates.  Microsoft +4

```
server_rtt: 53984
server_rtt_packets: 1
server_rtt_sum: 53984
site: imreallynotbatman.com
src_content: username=admin&task=login&return=aw5kZXgucGhw&option=com_login&passwd=12345678&9d873c2becd118318849d13cf18b60ff=1
src_headers: POST /joomla/administrator/index.php HTTP/1.1
Accept-Encoding: identity
Content-Length: 113
Host: imreallynotbatman.com
User-Agent: Python-urllib/2.7
Connection: close
Cookie: 7598a3465c906161e060ac551a9e0276=p5iqb7foa0q92mk0tnr2i8lnc0
Content-Type: application/x-www-form-urlencoded

src_ip: 23.22.63.114
src_mac: 08:5B:0E:93:92:AF
src_port: 46183
status: 303
time_taken: 11072571
timestamp: 2016-08-10T21:45:10.253339Z
transport: tcp
uri: /joomla/administrator/index.php
uri_path: /joomla/administrator/index.php
```

Investigating the AWS service IP address 23.22.63.114.

- I get many items about POST requests from 23.22.63.114 --> 192.168.250.70:80
with credential form data. And it records that useragent: Python-urllib/2.7 [**Urllib or
urllib2 standard libraries in Python 2.7 when making HTTP requests. --- google**]

Hide Fields

All Fields

linecount 1

a location 1

missing_packets_in 1

missing_packets_out 2

a network_interface 1

packets_in 2

packets_out 2

a product 1

a proto 1

a punct 2

reply_time 100+

a request 1

request_ack_time 100+

request_time 1

response_ack_time 100+

response_time 1

a sc_date 50

a server 1

server_rtt 100+

server_rtt_packets 2

server_rtt_sum 100+

a site 1

a splunk_server 1

a src 2

a src_content 100+

a src_headers 100+

a src_ip 2

a src_mac 1

src_port 100+

status 1

a tag 1

a tag::eventtype 1

time_taken 100+

timeendpos 2

a timestamp 100+

timestartpos 2

a transport 2

a url 1

a url_path 1

a url 1

a vendor 1

src_content

>100 Values, 25.015% of events

Selected

Reports

Top values

Top values by time

Rare values

Events with this field

Top 10 Values	Count	%
username=admin&0960d493674eb04861bd64da9b662118=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=arthur	1	0.243%
username=admin&0edae02d7478dfb41641700ef384807a=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=bigdaddy	1	0.243%
username=admin&115c3aa6072f4b02b4354909431510f6=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=blazer	1	0.243%
username=admin&12c709bcc2e14d5a015f054d18d36537=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=fire	1	0.243%
username=admin&2a2ddf97716c1d1e9da21cdaf82b231e=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=777777	1	0.243%
username=admin&2c340c4e46444ba249ff7e599e6dfa52=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=flower	1	0.243%
username=admin&32c15329bc3f78039869bb3bf17c28a6=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=zzzzzz	1	0.243%
username=admin&33fb6e7c85dfd116036c59ddf617d2f1=1&task=login&	1	0.243%

Brute force attempts happened on username: admin.

Investigate the IP address 40.80.148.42

- search Get request



8/10/16
10:21:18.468 PM

```
{ [-]
  dest_ip: 192.168.250.70
  dest_port: 80
  event_type: http
  flow_id: 3318498196
  http: { [+]
  }
  in_iface: eth1
  proto: TCP
  src_ip: 40.80.148.42
  src_port: 49501
  timestamp: 2016-08-10T16:21:18.468110-0600
  tx_id: 1
}
```

Show as raw text

Event Actions ▾

Type	☒	Field	Value	Actions
Selected	☒	host ▾	suricata-ids.waynecorpinc.local	▾
	☒	source ▾	/var/log/suricata/eve.json	▾
	☒	sourcetype ▾	suricata	▾
Event	☐	bytes ▾	16684	▾
	☐	dest ▾	imreallynotbatman.com	▾
	☐	dest_ip ▾	192.168.250.70	▾
	☐	dest_port ▾	80	▾
	☐	dvc ▾	suricata-ids.waynecorpinc.local	▾
	☐	event_type ▾	http	▾
	☐	eventtype ▾	suricata_eve_http (web)	▾
	☐	flow_id ▾	3318498196	▾
	☐	http.hostname ▾	imreallynotbatman.com	▾

8/10/16
10:18:12.756 PM

```

app_proto: http
dest_ip: 40.80.148.42
dest_port: 49494
event_type: fileinfo
fileinfo: { [+]
}
flow_id: 10112440
http: { [+]
}
in_iface: eth1
proto: TCP
src_ip: 192.168.250.70
src_port: 80
timestamp: 2016-08-10T16:18:12.756355-0600

```

Show as raw text

Event Actions ▾

Type	☒ Field	Value	Actions
Selected	☒ host ▾	suricata-ids.waynecorpinc.local	▾
	☒ source ▾	/var/log/suricata/eve.json	▾
	☒ sourcetype ▾	suricata	▾
Event	☐ app ▾	http	▾
	☐ app_proto ▾	http	▾
	☐ bytes ▾	828	▾
	☐ dest ▾	imreallynotbatman.com	▾
	☐ dest_ip ▾	40.80.148.42	▾
	☐ dest_port ▾	49494	▾
	☐ dvc ▾	suricata-ids.waynecorpinc.local	▾
	☐ event_type ▾	fileinfo	▾
	☐ file_size ▾	828	▾
	☐ file_state ▾	CLOSED	▾
	☐ file_stored ▾	false	▾

- I have found that 3791.exe was uploaded. Then I search "EventCode=1" for the execution of the executable. I got 5 items. From 9:56:18 ~10:08:13. The commandline is "cmd.exe /c "3791.exe 2>&1"

8/10/16
9:56:18.000 PM

```

<Event xmlns="http://schemas.microsoft.com/win/2004/08/events/event"><System><Provider Name="Microsoft-Windows-Sysmon" Guid="{5770385F-C22A-43E0-BF4C-06F5698FB093}" /><EventID>1</EventID><Version>5</Version>
<Level>4</Level><Task>1</Task><Opcode>0</Opcode><Keywords>0x8000000000000000</Keywords><TimeCreated SystemTime="2016-08-10T21:56:18.142461700Z" /><EventRecordID>428881</EventRecordID><Correlation></Correlation></Execution
ProcessID="1296" ThreadID="1416" /><Channel>Microsoft-Windows-Sysmon/Operational</Channel><Computer>we1149srv.waynecorpinc.local</Computer><Security UserID="S-1-5-18" /></System><EventData><Data Name="UtcTime"
>2016-08-10 21:56:18.142</Data><Data Name="ProcessGuid">{E50080EA-A302-57AB-8000-00102E63C301}</Data><Data Name="ProcessId">2836</Data><Data Name="Image">C:\Windows\System32\cmd.exe</Data><Data Name="Command
Line">cmd.exe /c "3791.exe 2>&1"&lt;/Data><Data Name="CurrentDirectory">C:\inetpub\wwwroot\joomla</Data><Data Name="User">NT AUTHORITY\SYSTEM</Data><Data Name="LogonGuid">{E50080EA-219E-57AA-0000-8028E303
0000}</Data><Data Name="LogonId">0x3e3</Data><Data Name="TerminalSessionId">0</Data><Data Name="IntegrityLevel">High</Data><Data Name="Hashes">SHA1=F5CFD4078EA702B40A29F21F8C29AF23341C59EC_ND5=59A104FACD7833
3F76C4142CD4203ABA_SHA256=E1A88651FB1BAF0A629D34BAEE6F0F908E0337BF6CE09F4B3AB081C23D91BA_INPHSH=5B13496C2360F7789A86B1BBF93CD3</Data><Data Name="ParentProcessId">{E50080EA-A0A8-57AB-8000-00107EEAA70
1}</Data><Data Name="ParentProcessId">1208</Data><Data Name="ParentImage">C:\Program Files (x86)\PHP\v5.5\php-cgi.exe</Data><Data Name="ParentCommandLine">"C:\Program Files (x86)\PHP\v5.5\php-cgi.exe"</Data>
</EventData></Event>

```

host = we1149srv | source = WinEventLog:Microsoft-Windows-Sysmon/Operational | sourcetype = xmlwineventlog

From the picture above, I know the 3791.exe runs by cmd command. And the cmd run by php-cgi.exe. So I can guess a php webshell has been built and has the function and access to run cmd.exe. The agent.php uploaded by the attacker may be the suspicious php file. By analyzing the

behaviors of agent.php, I have much evidence about attacker request agent.php with http GET/POST requests.